

DataForge ML — Model Threat Assessment

Field	Your Finding
Model File	genomics_analyzer_v2.pkl
Source Repository	huggingface.co/logix-community/genomics-analyzer-v2
Serialisation Format	Pickle (.pkl), a legacy Python serialisation format that can execute embedded code during loading/deserialisation.
Threats Detected	Infected files: 1; Dangerous globals: 1
Threat Type	subprocess check_output
Threat Classification	MITRE ATLAS: AML.T0010 — ML Supply Chain Compromise Technique: embedding malicious payload in .pkl model weights via public repository
Supply Chain Risk Factors	❖ Unverified account ❖ No checksum provided ❖ Licence is unknown. ❖ No model card is provided. ❖ The model uses the legacy. pkl format.
Business Impact	Loading the malicious pickle could execute the embedded payload in the DataForge ML production pipeline. Because the pipeline processes patient sample data, successful exploitation could allow an attacker to access, modify, or exfiltrate sensitive data and potentially execute additional commands using the privileges available to the pipeline. This could result in data exposure, service disruption, and compromise of the production environment.
Remediation Plan	Replace unsafe Pickle loading with safetensors; add Picklescan as a mandatory pre-load security gate; use a verified model source; and introduce model integrity verification before allowing models into the production pipeline.